SIZMA TESTİ RAPORU

Rapor Tarihi	-
Hazırlayan	Ömer Faruk Baysal
Test Türü	PortSwigger Web Academy Lab

1. CSRF: Token doğrulamasının atlatılması

Bu raporda PortSwigger Web Security Academy'de yer alan CSRF: Token doğrulamasının atlatılmasıyla alakalı lablar ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın e-posta adresi değiştirme işlevinde Siteler Arası İstek Sahteciliği (CSRF) zafiyeti tespit edilmiştir. Uygulama bu işlem için CSRF belirteci (token) tabanlı bir savunma uygulamakta; ancak belirteç, uygulamanın oturum yönetim sistemine düzgün biçimde entegre edilmediğinden savunma atlatılabilmektedir. Test sırasında bu eksikliğin üç farklı biçimde ortaya çıktığı gözlenmiştir: belirtecin kullanıcı oturumuna hiç bağlanmaması (Durum 1), oturum-dışı ayrı bir çereze bağlanması (Durum 2) ve belirtecin çerezde kopyalanmasına dayanan güvensiz "double submit" tekniğinin kullanılması (Durum 3).

Her üç durumda da bir saldırgan, oturumu açık bir kullanıcıyı hazırladığı kötü niyetli bir sayfaya yönlendirerek, kullanıcının bilgisi ve onayı olmaksızın hesabına tanımlı e-posta adresini değiştirebilmektedir. Zafiyet, her durum için hazırlanan kavram kanıtları (PoC) ile doğrulanmıştır. E-posta adresinin ele geçirilmesi, parola sıfırlama süreci aracılığıyla hesabın tümüyle ele geçirilmesine (account takeover) kadar ilerleyebileceğinden zafiyetin ivedilikle giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Durum 1: CSRF belirtecinin kullanıcı oturumuna bağlı olmaması

Hedef uygulamanın e-posta değiştirme işlevi "/my-account/change-email" durum değiştiren bu işlemi Siteler Arası İstek Sahteciliği'ne karşı korumak amacıyla bir CSRF belirteci (token) kullanmaktadır. Yapılan incelemede belirtecin sunucu tarafında gerçekten doğrulandığı görülmüştür; belirtecin eksik olduğu veya geçersiz bir değer taşıdığı istekler reddedilmektedir.

Ancak belirteç doğrulaması yalnızca belirtecin geçerliliğini denetlemekte, belirtecin isteği gönderen kullanıcının oturumuna ait olup olmadığını denetlememektedir. Bir kullanıcının oturumu için üretilmiş geçerli bir belirteç, başka bir kullanıcının oturumundan gönderilen istekte de kabul edilmektedir. Bu durum, belirtecin uygulamanın oturum yönetim sistemiyle ilişkilendirilmemiş olmasından kaynaklanmaktadır.

Belirtecin oturuma bağlı olmaması nedeniyle saldırgan, kendi hesabından elde ettiği geçerli bir belirteci saldırı sayfasına gömerek kullanabilmektedir. Kurban bu sayfayı ziyaret ettiğinde, istek kurbanın oturum çerezi ile saldırganın geçerli belirteci birlikte gönderilmekte;

belirteç oturuma bağlı olmadığından sunucu isteği meşru kabul etmekte ve işlemi gerçekleştirmektedir. Bu da işlevi, belirteç savunmasının varlığına rağmen CSRF saldırısına açık hale getirmektedir.

Durum 2: CSRF belirtecinin oturum-dışı bir çereze bağlı olması

Hedef uygulamanın e-posta değiştirme işlevi, Durum 1'de olduğu gibi bir CSRF belirteci (token) kullanmaktadır. Ancak bu belirteç, kullanıcının oturum çerezi (session) yerine ayrı bir çereze (csrfKey) bağlanmıştır. Sunucu, isteği doğrularken istek gövdesindeki csrf belirteci ile csrfKey çerezindeki değerin birbiriyle tutarlı olup olmadığını denetlemektedir.

Yapılan testte, csrfKey çerezi geçersiz bir değerle değiştirildiğinde (belirteç sabit tutulmasına rağmen) isteğin "Invalid CSRF token" yanıtıyla reddedildiği; eşleşen bir csrf + csrfKey çifti gönderildiğinde ise isteğin kabul edildiği görülmüştür. Bu, belirtecin gerçekten csrfKey çerezine karşı doğrulandığını, ancak bu çerezin kullanıcının oturumuna ait olup olmadığının denetlenmediğini ortaya koymaktadır. Belirteç–çerez çifti kendi içinde tutarlı olduğu sürece, çiftin hangi oturuma ait olduğu önemsenmemektedir.

Bu tasarım, tek başına yeterince zayıf olmasa da, uygulamada bulunan bir çerez enjeksiyonu (cookie injection) zafiyetiyle birleştiğinde istismar edilebilir hale gelmektedir. Uygulamanın arama işlevi, kullanıcı girdisini yanıtın Set-Cookie başlığına yansıtmakta ve girdiye CRLF (%0d%0a) karakterleri eklenerek kurbanın tarayıcısına saldırgan kontrolündeki bir csrfKey çerezi yazılabilmektedir. Böylece saldırgan, kendi ürettiği eşleşen csrf + csrfKey çiftini kurbana zorla kabul ettirerek belirteç doğrulamasını atlatabilmektedir. Sonuç olarak işlev, belirteç savunmasının varlığına rağmen CSRF saldırısına açıktır.

Durum 3: CSRF belirtecinin çerezde kopyalanması ("double submit")

Hedef uygulamanın e-posta değiştirme işlevi, Siteler Arası İstek Sahteciliği'ne karşı "double submit" adı verilen tekniği kullanmaktadır. Bu teknikte CSRF belirteci hem bir çerezde hem de istek gövdesinde gönderilmekte; sunucu, isteğin geçerliliğini yalnızca bu iki değerin birbirine eşit olup olmadığını karşılaştırarak belirlemektedir.

Bu yaklaşımın temel kusuru, sunucunun belirtecin değerini doğrulamaması, oturumla ilişkilendirmemesi ve sunucu tarafında saklamamasıdır; yalnızca çerezdeki ve gövdedeki değerlerin tutarlılığına bakılmaktadır. Yapılan testte, gövdedeki csrf parametresi ile csrf çerezi birlikte tamamen keyfi bir değere (aaaa) ayarlandığında isteğin 302 Found yanıtıyla kabul edildiği görülmüştür. Bu, geçerli bir belirteç elde etmeye dahi gerek olmadığını; saldırgan tarafından belirlenen herhangi bir değerin, iki yerde de aynı olduğu sürece doğrulamayı geçtiğini ortaya koymaktadır.

Bu kusur, uygulamanın arama işlevindeki bir çerez enjeksiyonu (cookie injection) zafiyetiyle birleştiğinde istismar edilebilir hale gelmektedir. Arama terimi yanıtın Set-Cookie başlığına yansıtılmakta ve terime CRLF (%0d%0a) karakterleri eklenerek kurbanın tarayıcısına saldırgan kontrolündeki bir csrf çerezi yazılabilmektedir. Böylece saldırgan, aynı keyfi değeri hem çereze (enjeksiyon yoluyla) hem de istek gövdesine yerleştirerek doğrulamayı atlatabilmektedir. Sonuç olarak işlev, belirteç savunmasının varlığına rağmen CSRF saldırısına açıktır.

4. Risk Seviyesi

Risk Seviyesi	Yüksek
CVSS v3.1 Skoru	8.1
CWE	CWE-352

5. Etki

Zafiyetin başarıyla istismar edilmesi durumunda saldırgan, oturumu açık bir kurbanın hesabına tanımlı e-posta adresini, kurbanın bilgisi ve onayı olmaksızın değiştirebilmektedir. Saldırı, kurbanın yalnızca saldırgan kontrolündeki bir sayfayı ziyaret etmesiyle, herhangi bir ek etkileşim gerektirmeden gerçekleşmektedir.

E-posta adresinin saldırgan tarafından belirlenen bir adresle değiştirilmesi, tek başına bir bütünlük ihlali oluşturmasının yanı sıra, uygulamanın parola sıfırlama sürecinin bu adres üzerinden işlemesi halinde hesabın tümüyle ele geçirilmesine (account takeover) olanak tanır. Bu durumda saldırgan, kurbanın hesabındaki kişisel verilere erişebilir ve hesap üzerinde kurban adına işlem yapabilir. Kimliğe bürünme yoluyla gerçekleştirilebilecek işlemler, uygulamanın niteliğine bağlı olarak itibar ve uyumluluk açısından da doğrudan etki yaratır.

6. Proof Of Concept

Durum 1 için PoC

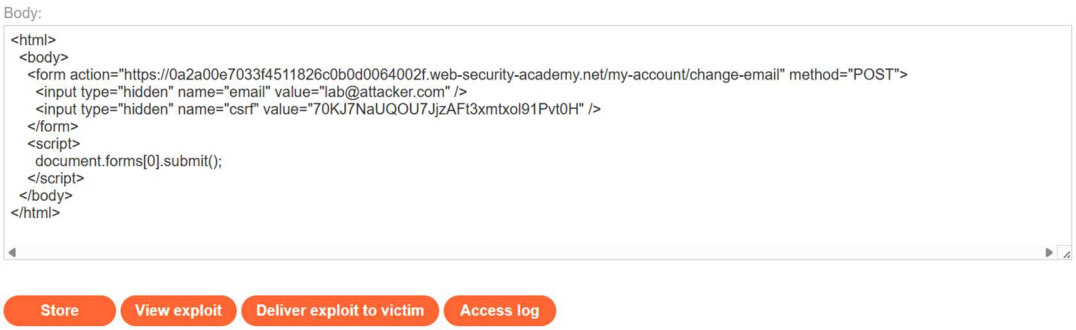
Uygulamaya wiener hesabıyla giriş yapılmış ve e-posta değiştirme işlevi kullanılmıştır. İşleme ait istek Burp Suite ile yakalandığında, istek gövdesinde email parametresine ek olarak bir csrf belirteci (token) bulunduğu görülmüştür. Bu, uygulamanın Siteler Arası İstek Sahteciliği'ne karşı bir belirteç doğrulaması uyguladığını göstermektedir.

Belirtecin gerçekten doğrulanıp doğrulanmadığını sınamak için istek Burp Repeater'a aktarılmıştır. csrf belirteci tamamen kaldırıldığında ve ayrıca belirtecin bir karakteri değiştirildiğinde, isteğin her iki durumda da reddedildiği ("Invalid CSRF token") gözlenmiştir. Bu aşamada işlev, geçerli bir belirteç gerektirdiğinden korunuyor görünmektedir.

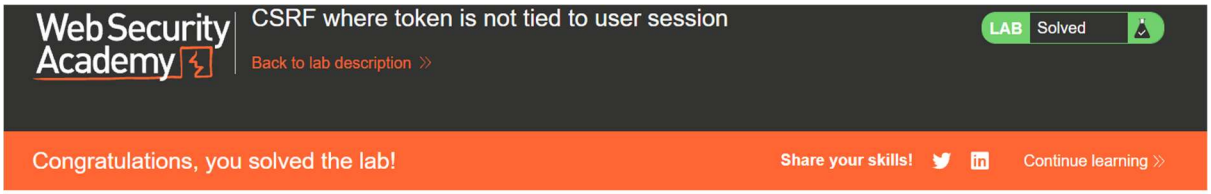
Ancak belirtecin doğrulanıyor olması tek başına yeterli bir güvence değildir. Belirtecin, isteği gönderen kullanıcının oturumuna bağlı olup olmadığı da sınanmalıdır. Bunu doğrulamak için ikinci bir hesapla (carlos) ayrı bir oturum açılmış ve bu oturuma ait geçerli bir CSRF belirteci elde edilmiştir. Ardından, wiener oturumuna ait e-posta değiştirme isteği yalnızca csrf değeri carlos oturumundan alınan belirteçle değiştirilerek gönderilmiş; isteğin 302 Found yanıtıyla kabul edilip işlendiği görülmüştür.

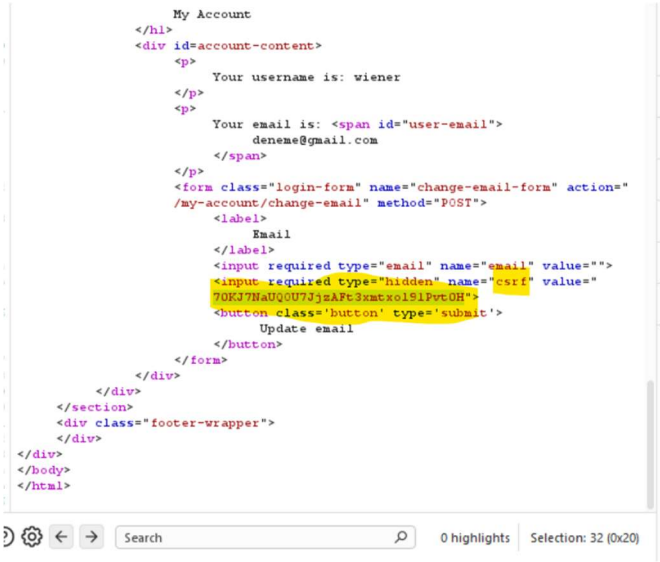
Bu sonuç, sunucunun belirtecin yalnızca geçerliliğini kontrol ettiğini, ancak belirtecin isteği gönderen kullanıcının oturumuna ait olup olmadığını doğrulamadığını ortaya koymaktadır. Dolayısıyla herhangi bir kullanıcıya ait geçerli bir belirteç, başka bir kullanıcının oturumunda da kabul edilmektedir.

Zafiyet, saldırganın kendi hesabından elde ettiği geçerli bir belirteci saldırı sayfasına gömmesiyle istismar edilebilmektedir. Kurban bu sayfayı ziyaret ettiğinde, istek kurbanın oturum çerezi ile saldırganın geçerli belirteci birlikte gönderilmekte ve belirteç oturuma bağlı olmadığından sunucu tarafından kabul edilmektedir. Kullanılan kavram kanıtı (PoC) aşağıdadır:



Kavram kanıtı exploit sunucusunda barındırılıp kurbana teslim edildiğinde, kurbanın e-posta adresi saldırganın belirlediği değerle değiştirilmiş ve lab "Solved" durumuna geçmiştir.



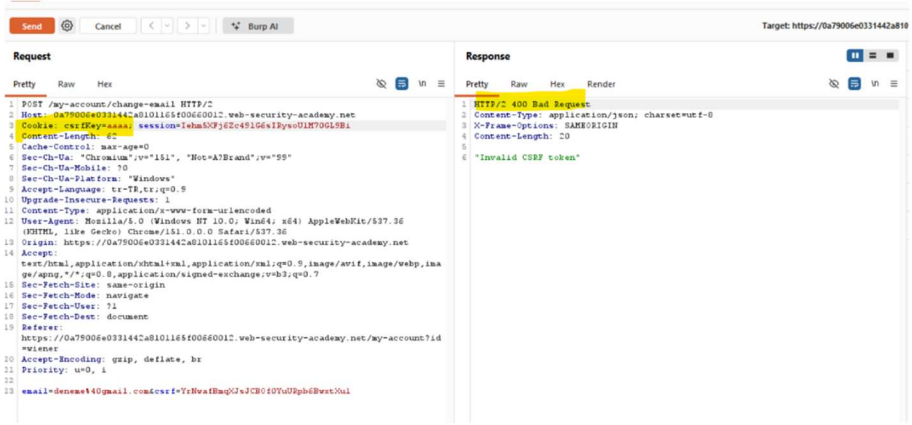


wiener hesabındayken GET metodundan csrf değeri alınmıştır.

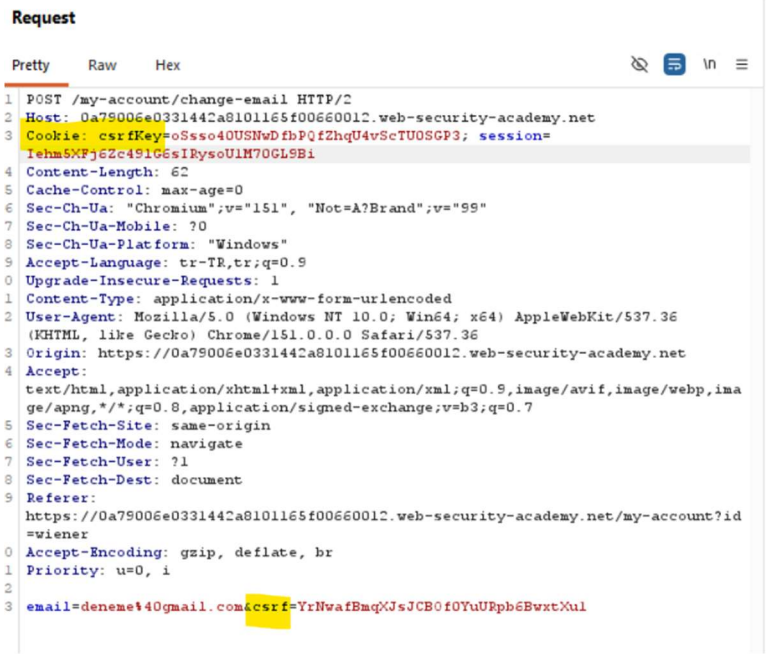
Durum 2 için PoC

Uygulamaya wiener hesabıyla giriş yapılıp e-posta değiştirme işlevi kullanıldığında, işleme ait istek Burp Suite ile yakalanmıştır. İstek gövdesinde bir csrf belirteci, çerez başlığında ise session çerezinden ayrı bir csrfKey çerezi bulunduğu görülmüştür. Bu, belirtecin oturumdan ayrı bir çereze bağlandığına işaret etmektedir.

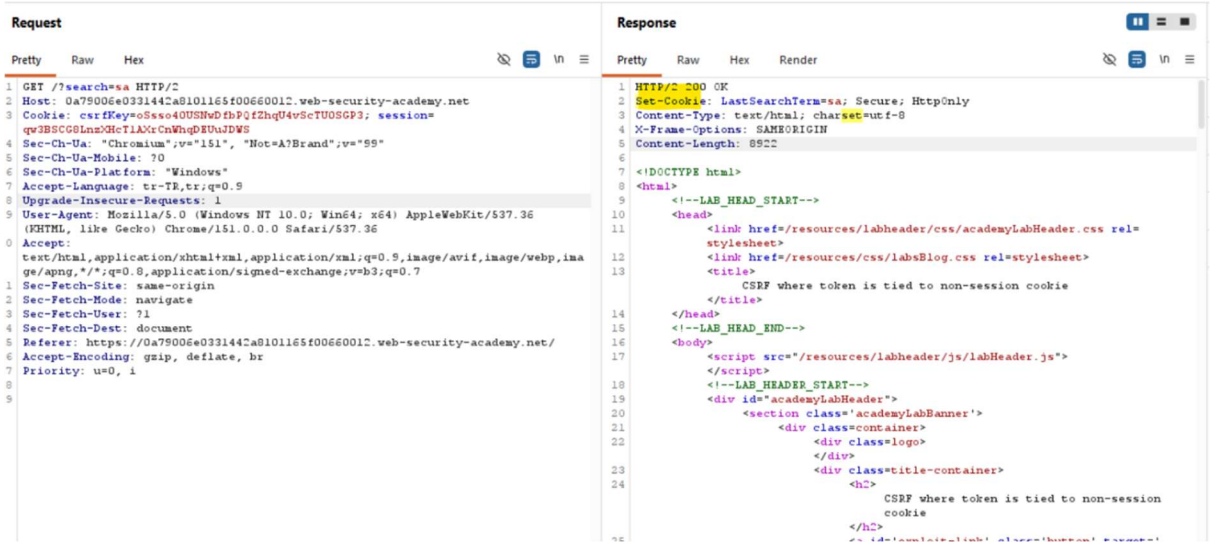
Belirtecin bu çereze bağlı olup olmadığını sınamak için istek Burp Repeater'a aktarılmıştır. csrfKey çerezi geçersiz bir değerle (aaaa) değiştirildiğinde, sunucu 400 Bad Request – "Invalid CSRF token" yanıtı döndürmüştür. Bu, belirtecin csrfKey çerezine karşı doğrulandığını göstermektedir.



Ardından, birbiriyle eşleşen bir csrf + csrfKey çifti aynı istekte gönderilmiş ve isteğin kabul edildiği görülmüştür. Bu sonuç, doğrulamanın yalnızca belirteç ile çerezin birbiriyle tutarlılığına dayandığını; çiftin kullanıcının oturumuna ait olmasının gerekmediğini ortaya koymaktadır.



- Belirteç–çerez çiftinin oturumdan bağımsız olması, saldırganın kendi ürettiği çifti kurbana kabul ettirebilmesi durumunda zafiyeti istismar edilebilir kılmaktadır. Bunu mümkün kılan ikinci zafiyet, uygulamanın arama işlevinde tespit edilmiştir: arama terimi yanıtın Set-Cookie başlığına yansıtılmakta ve terime CRLF (%0d%0a) karakterleri eklenerek yanıta ikinci bir Set-Cookie: csrfKey=... satırı enjekte edilebilmektedir.



Bu iki zafiyet, aşağıdaki kavram kanıtında (PoC) zincirlenmiştir. Sayfa yüklendiğinde <img> etiketi arama endpoint'ine istek atarak kurbanın tarayıcısına saldırganın csrfKey çerezini yazmakta; isteğin ardından (onerror) e-posta değiştirme formu, saldırganın bu çerezle eşleşen csrf belirtecini taşıyacak şekilde otomatik olarak gönderilmektedir. Belirteç ile enjekte edilen çerez birbiriyle tutarlı olduğundan istek kabul edilmektedir.

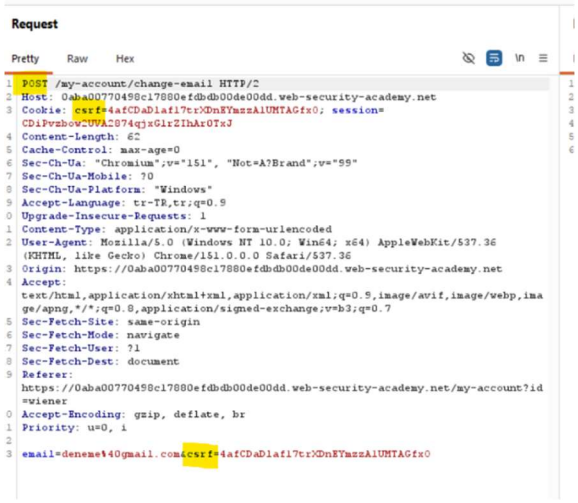
Body:

```
<html>
  <body>
    <form action="https://0a79006e0331442a8101165f00660012.web-security-academy.net/my-account/change-email" method="POST">
      <input type="hidden" name="email" value="lab@attacker.com" />
      <input type="hidden" name="csrf" value="YrNwafBmqXJsJCBOf0YuURpb6BwxtXu1" />
    </form>
    <img src="https://0a79006e0331442a8101165f00660012.web-security-academy.net/?search=x%0d%0aSet-
Cookie:%20csrfKey=oSsso40USNwDfbPQfZhqU4vScTU0SGP3%3b%20SameSite=None" onerror="document.forms[0].submit();" />
  </body>
</html>
```

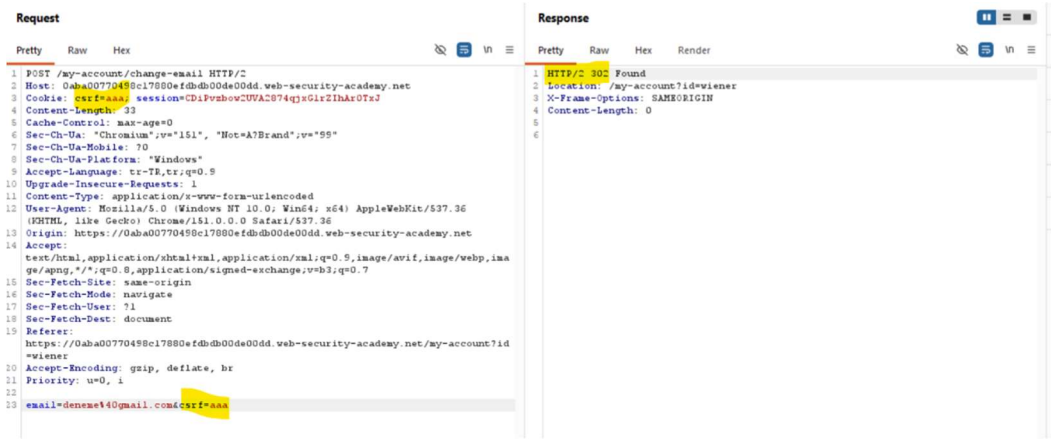
Kavram kanıtı exploit sunucusunda barındırılıp kurbana teslim edildiğinde, kurbanın e-posta adresi saldırganın belirlediği değerle değiştirilmiştir.

Durum 3 için PoC

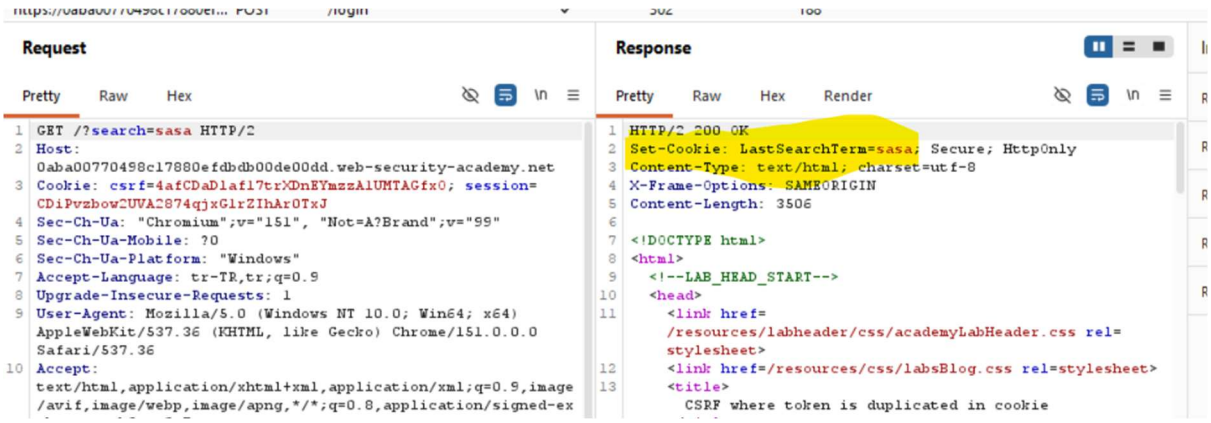
Uygulamaya wiener hesabıyla giriş yapılıp e-posta değiştirme işlevi kullanıldığında, işleme ait istek Burp Suite ile yakalanmıştır. İstek gövdesindeki csrf belirtecinin, aynı değerle bir csrf çerezinde de tekrarlandığı görülmüştür. Belirtecin hem gövdede hem çerezde birebir aynı olması, uygulamanın "double submit" tekniğini kullandığına işaret etmektedir.



Sunucunun belirteci doğrulayıp doğrulamadığını sınamak için istek Burp Repeater'a aktarılmıştır. Gövdedeki csrf parametresi ve csrf çerezi, birlikte tamamen keyfi bir değere (aaaa) ayarlanarak gönderilmiştir. İstek 302 Found yanıtıyla kabul edilmiştir. Bu sonuç, sunucunun belirtecin değerini doğrulamadığını; yalnızca gövde ile çerezdeki değerlerin birbirine eşit olmasını yeterli gördüğünü kanıtlamaktadır.



Saldırının gerçekleştirilebilmesi için saldırganın, belirlediği değeri kurbanın tarayıcısındaki çereze yazabilmesi gerekmektedir. Bunu mümkün kılan çerez enjeksiyonu zafiyeti, uygulamanın arama işlevinde tespit edilmiştir: arama terimi yanıtın Set-Cookie başlığına yansıtılmakta ve terime CRLF (%0d%0a) karakterleri eklenerek yanıta ikinci bir Set-Cookie: csrf=... satırı enjekte edilebilmektedir.



Bu iki zafiyet aşağıdaki kavram kanıtında (PoC) zincirlenmiştir. Sayfa yüklendiğinde <img> etiketi arama endpoint'ine istek atarak kurbanın tarayıcısına csrf=fake çerezini yazmakta; ardından (onerror) e-posta değiştirme formu, gövdesinde aynı fake değerini taşıyacak şekilde otomatik gönderilmektedir. Çerezdeki ve gövdedeki değerler eşit olduğundan istek kabul edilmektedir.

Body:

```
<html>
  <body>
    <form action="https://0aba00770498c17880efdbdb00de00dd.web-security-academy.net/my-account/change-email" method="POST">
      <input type="hidden" name="email" value="pwned@attacker.com" />
      <input type="hidden" name="csrf" value="fake" />
    </form>
    <img src="https://0aba00770498c17880efdbdb00de00dd.web-security-academy.net/?search=x%0d%0aSet-Cookie:%20csrf=fake%3b%20SameSite=None"
onerror="document.forms[0].submit();" />
  </body>
</html>
```

Kavram kanıtı exploit sunucusunda barındırılıp kurbana teslim edildiğinde, kurbanın e-posta adresi saldırganın belirlediği değerle değiştirilmiştir.

7. Çözüm Önerisi

CSRF belirteci kullanıcının oturumuna sıkı biçimde bağlanmalıdır. Belirteç, üretildiği kullanıcı oturumuyla ilişkilendirilerek sunucu tarafında saklanmalı; doğrulama sırasında yalnızca belirtecin geçerliliği değil, isteği gönderen kullanıcının oturumuna ait olduğu da denetlenmelidir. Bu, bir kullanıcının belirtecinin başka bir kullanıcının oturumunda kullanılmasını engeller. (Durum 1)

Belirteç, oturum-dışı ayrı bir çereze bağlanmamalıdır. Belirtecin geçerliliği, oturumdan bağımsız bir çerez (csrfKey vb.) üzerinden değil, oturumla ilişkilendirilmiş sunucu tarafı kayda karşı doğrulanmalıdır. (Durum 2)

Durum tutmayan (stateless) "double submit" yaklaşımı kullanılmamalıdır. Belirtecin yalnızca istek gövdesi ile çerezde eşit olması yeterli görülmemeli; belirteç, sunucu tarafında oturuma bağlı olarak üretilip saklanmalı ve her istekte bu kayda karşı doğrulanmalıdır. (Durum 3)

Kullanıcı girdisi yanıt başlıklarına yansıtılmamalıdır. Girdi hiçbir koşulda Set-Cookie başlığına yansıtılmamalı; CRLF enjeksiyonuna karşı temizlenmeli ve başlık enjeksiyonu engellenmelidir. Bu, Durum 2 ve Durum 3'ün istismarını mümkün kılan çerez enjeksiyonu vektörünü ortadan kaldırır. (Durum 2 ve 3 ortak)

İsteğin kaynağı sunucu tarafında doğrulanmalıdır. Durum değiştiren işlemlerde Origin ve Referer başlıkları kontrol edilerek, isteğin yalnızca uygulamanın kendi kaynağından kabul edilmesi sağlanmalıdır.

Tek bir kontrole güvenilmemelidir. Yukarıdaki önlemler savunma derinliği ilkesiyle birlikte uygulanmalı; herhangi bir kontrolün atlatılması durumunda diğerlerinin koruma sağlaması hedeflenmelidir.

Düzeltme sonrası yeniden test (retest) yapılmalıdır. Uygulanan önlemlerin zafiyeti gerçekten giderdiğini doğrulamak için, düzeltmenin ardından aynı işlev yeniden test edilmelidir.

8.Sonuç

Yapılan test sonucunda, hedef uygulamanın e-posta değiştirme işlevinin Siteler Arası İstek Sahteciliği (CSRF) zafiyetine açık olduğu tespit ve kavram kanıtları ile doğrulanmıştır. Uygulama belirteç tabanlı bir savunma içermekle birlikte, belirtecin oturum yönetim sistemine düzgün entegre edilmemesi nedeniyle üç farklı biçimde (belirtecin oturuma bağlanmaması, oturum-dışı çereze bağlanması ve çerezde kopyalanması) atlatılabilmektedir. İkinci ve üçüncü durumlarda saldırı, uygulamanın arama işlevindeki bir çerez enjeksiyonu zafiyetiyle zincirlenerek gerçekleştirilmiştir. Zafiyet, hesabın tümüyle ele geçirilmesine kadar ilerleyebilecek etkisi nedeniyle yüksek risk seviyesinde değerlendirilmiş olup, önerilen önlemlerin uygulanarak ivedilikle giderilmesi tavsiye edilmektedir.
